

I. Request

1. The Institute of Financial Management of Social Security, IP (IGFSS), the Institute of Social Security of the Azores, I.P.R.A. (ISSA, IPRA), the Institute of Social Security of Madeira, IP-RAM (ISSM, IP-RAM), the Institute of Informatics, IP (II, I.P.), and the Caixa de Previdência dos Advogados e dos Solicitadores (CPAS) submitted to the National Data Protection Commission (hereinafter CNPD), for opinion, the draft Protocol aimed at defining the terms and conditions of communication and interoperability between the involved institutions for the purposes of participation and execution of debt of the Caixa de Previdência dos Advogados e dos Solicitadores (CPAS).
2. The parties to this Protocol are the Institute of Financial Management of Social Security, IP (IGFSS), the Institute of Social Security of the Azores, I.P.R.A. (ISSA, IPRA), the Institute of Social Security of Madeira, IP-RAM (ISSM, IP-RAM), the Institute of Informatics, IP (II, I.P.), and the Caixa de Previdência dos Advogados e dos Solicitadores (CPAS).
3. The CNPD issues an opinion within the scope of its powers and competencies as an independent administrative authority with the authority to oversee the processing of personal data, conferred by paragraph c) of no. 1 of article 57, in conjunction with paragraph b) of no. 3 of article 58, and with no. 4 of article 36, all of Regulation (EU) 2016/679, of April 27, 2016, General Data Protection Regulation (hereinafter GDPR), in conjunction with the provisions of article 3, no. 2 of article 4, and paragraph a) of no. 1 of article 6, all of Law no. 58/2019, of August 8, which implements the GDPR in the internal legal order.

II. Analysis

1. Decree-Law no. 42/2001, of February 9, regarding the coercive collection of debts to Social Security, also applies to all amounts owed to the Caixa de Previdência dos Advogados e Solicitadores (CPAS), whereby, for the purposes of the aforementioned diploma, the CPAS is equated to a social security institution.
2. No. 1 of article 18-A of Decree-Law no. 42/2001, of February 9, added by article 416 of Law no. 2/2020, of March 31, establishes that for the purposes of reporting the debt related to the CPAS, specific channels of communication and interoperability between the involved institutions are established.
3. In turn, no. 2 of the aforementioned article 18-A provides that the terms and conditions of communication and interoperability are established by a protocol to be concluded between the IGFSS, I.P., the ISSA, IPRA, the ISSM, IP-RAM, and the CPAS. Dispatch 6542/2023, published on June 16, 2023, defined the necessary procedures for the application of no. 1 of article 18-A of Decree-Law no. 42/2001, of February 9.

4. In these terms, the data processing carried out under this protocol has as its lawful basis the provisions of paragraph c) of no. 1 and no. 3 of article 6 of the GDPR.
5. It is thus important to regulate the sharing of personal data between the ISS, I.P., the SCML, and the ACSS, I.P. for the purposes of participation and execution of debt of the CPAS, which is now being realized.
6. Under Clause 2 of the Protocol, the electronic communication of data between the systems of the contracting entities is carried out via web services, specifically implemented to protect the provision of data, and through a secure channel, with the parties agreeing to the implementation of this interoperability process.
7. The data to be exchanged between the parties are: CPAS Beneficiary Number; Tax Identification Number; Debt Identifier; Debt Assessment Period; Debt Amount; Nature of the Debt; Indication for the Requirement of Interest; Payment Deadline; Start Date of Prescription; Start Date of Interest Requirement; Reason for Cancellation; Cancellation Date; Reporting Date; Error Reasons; Debt

Status; Information on Prescribed Debt; Debt and Interest Payment Amount; Canceled Debt and Interest Payment Amount; Debt and Interest Prescription Amount; Cancellation of Debt and Interest Prescription Amount; Amount Refunded for Debt and Interest; Payment Value Date; Prescription Value Date; Cancellation Payment Value Date; Identification of the Certificate / Tax Execution Process; Amount to be Reimbursed; Reason for the Reimbursement Request; IBAN for where the payment should be made.

8. The personal data subject to processing are adequate, relevant, and necessary for the purposes at hand, in compliance with the data minimization principle set forth in paragraph c) of no. 1 of article 5 of the GDPR.

9. Regarding the conditions for electronic communication of data, Clause 3 establishes that communication between systems requires prior authentication between II, I.P. and CPAS, through the assignment of an application user and a password used exclusively for electronic communication. On this aspect of authentication, the following recommendations should be made: i - there should be a policy for the use of strong credentials with long, unique, complex passwords including numbers, symbols, uppercase and lowercase letters; ii - accounts should be blocked after several invalid login attempts; and iii - if feasible, the use of a password, preferably in combination with another factor (2FA).

10. The CPAS registers all information queries made and the information sent under this protocol. II, I.P. also keeps records of access and information sent under this Protocol, in accordance with its audit policy, retaining them for a period of 5 years, after which they are deleted. Regarding this retention period, it is recommended to elaborate on Clause 3, indicating the user profile that will have access to these audit records and with the

PAR/2023/100

2

indication of safeguards so that they are of restricted access. It is also proposed to include the provision for an automatic data deletion process after the retention period provided.

14. Clause 4 regulates the participation and cancellation of debts originating from the CPAS, which will be carried out automatically using the SID subsystem to facilitate communication between both systems. It should be noted that the initiation will only occur if the rules set forth in paragraph 2 of this Clause are met.

15. The relevant information regarding the debt reported by the CPAS will be included in the Debt Certificate, which can be materialized in digital format by the Social Security Information System based on the data transmitted electronically, including in this document the digitized image of the signature of the representative of the entity from which the debt originates (CPAS). It should be noted that this data is not included in the list of Clause 2, so its inclusion is suggested.

16. According to Clause 13 of the draft Protocol under review, which is now transcribed, the entities responsible for the processing of personal data are the IGFSS, ISSA, IP-RA, ISSM, IP-RAM, and the CPAS, which independently determine the purposes and means of processing the personal data to which they have access under this Protocol and are individually responsible for compliance with the GDPR.

17. The responsibility for the personal data processed by the IGFSS, ISSA, IPRA, ISSM, IP-RAM, and the CPAS is shared considering the following moments:

a) In the first instance, the CPAS, as an autonomous data controller for the data of its Beneficiaries, will transmit to the IGFSS the personal data indicated in Clause 2 to enable coercive collection by the IGFSS, ISSA, IPRA, ISSM, IP-RAM as determined by Decree-Law No. 42/2001, of February 9, corresponding to this transmission, for GDPR purposes, as a data transfer between autonomous responsible entities, which will be made by the CPAS entering the data into the platform and communicated via web services, as an organizational technical measure adopted by the Parties for this purpose, in accordance with Clauses 2 and 3;

b) In the second instance, the IGFSS, ISSA, IPRA, ISSM, IP-RAM, each as an autonomous and isolated data controller for the data of the CPAS Beneficiaries that concern them, will process the personal data indicated in Clause 2 to ensure coercive collection by the IGFSS, ISSA, IPRA, and

ISSM, IP-RAM, with II being subcontracted for this purpose.

18. Thus, as each of these entities is considered responsible for the data processing it performs, it is incumbent upon each of them to comply with the obligations set forth in Clause 14. It should be noted that among these obligations is the performance of their respective Data Protection Impact Assessments. According to Article 35 of the GDPR, such assessments must be conducted before the processing begins to allow for the adoption of appropriate technical and organizational measures to ensure a level of security appropriate to the identified risk.

19. From the above, it follows that the definition of the security measures to be adopted will occur at a later time than the signing of this Protocol, making it impossible for the CNPD to comment on their validity.

20. Regarding Clause 15, related to the obligations of the subcontractor, it states in paragraph 3 that the choice of further subcontractors is considered "delegated to the subcontractor, without prejudice to the provision of an updated list identifying them, accompanied by the applicable contractual conditions and the right to object." It should be noted that paragraph 2 of Article 28 of the GDPR provides for the possibility of a subcontractor hiring further subcontractors, giving the data controller the opportunity to oppose such changes.

21. It is understood, therefore, that the wording of Clause 15, paragraph 3 is too generic and permissive, failing to meet the legal requirements for subcontracting set forth in paragraphs 2 and 4 of Article 28 of the GDPR, since the subcontractor may only proceed with further subcontracting if those subcontractors present the "...". It is also suggested to replace the reference to the right to object with the possibility of opposing, as that expression is attributed in the GDPR to data subjects, according to Article 21.

22. Finally, it is important to reference Clause 18, related to security measures to be adopted under this Protocol, reaffirming what is stated in points 18 and 19 above regarding the fact that DPIAs will be conducted after the signing of this Protocol.

23. In addition to the measures outlined in this Clause, the CNPD reminds that in communications between II, I.P. and the data controllers, there must be the capacity to ensure the correct identity of the sender and recipient of the transmission of personal data. Namely, and according to the technical requirements of Resolution of the Council of Ministers No. 41/2018, it is recommended to use secure communication technology (e.g., VPN), with a strong authentication system (preferably through certificates), so that the transmission of data between entities in different technological environments is carried out securely.

24. It is also suggested that II, I.P. conduct periodic checks to ensure that the defined security measures are in place, ensuring that they are effective and updating them regularly, especially when processing or circumstances change, including those implemented by the controllers in data processing.